

## AGRIAI 2.0 | FORENSIC SOFTWARE EXAMINATION

# Complete Forensic Examination

Executive verdict, evidence boundaries and risk register

---

Volume 00

Prepared and authored solely by Thaddeus Nii Teiko Tagoe

Founder, designer and sole creator of AgriAI

Computer Science, University of Ghana

Repository examined: ThaddeusHackz/agriai-v2

Evidence commit: 991457272b7fec548e02c645c5593b930af5ea29

Examination date: 18 August 2026

Classification: Internal technical record

**Technical basis**

This document is grounded in direct source review, route enumeration, dependency audit, secret pattern scanning, strict TypeScript checking, ESLint, production compilation, PostgreSQL integration tests and local HTTP behavior tests. Live third party AI accounts were not available in the examination environment, so provider success is assessed from code paths and contracts rather than a claim of live production availability.

# 1. Examination mandate

The mandate was to explain, at engineering depth, how AgriAI was built, which code makes its AI functions possible, why its APIs return useful responses, how data and authentication work, and where failure or abuse can occur. The analysis treats source code as primary evidence. Product copy is accepted only when the implementation supports it.

# 2. Snapshot identity

| Property          | Observed value                                              |
|-------------------|-------------------------------------------------------------|
| Repository        | ThaddeusHackz/agriai-v2                                     |
| Commit            | 991457272b7fec548e02c645c5593b930af5ea29                    |
| Application       | agriai version 2.0.0                                        |
| Framework         | Next.js 16.2.10 App Router, React 19.2.4, TypeScript 5      |
| Source size       | 79 TS, TSX and CJS source files, 8,100 lines                |
| HTTP surface      | 27 route files exposing 40 method handlers                  |
| Data engine       | Atomic JSON document plus debounced PostgreSQL JSONB mirror |
| Primary AI        | Google Gemini through @google/genai                         |
| Fallback AI       | Cloudflare Workers AI Llama, then local knowledge           |
| Author of dossier | Thaddeus Nii Teiko Tagoe                                    |

# 3. What the system actually is

AgriAI is a single full-stack Next.js application, not a group of microservices and not a custom machine learning model. React client components collect farmer actions. Next.js route handlers validate requests and keep provider keys on the server. Library modules call Gemini, Cloudflare, Tavily, Wikipedia, DuckDuckGo, OpenWeatherMap, Open-Meteo, ElevenLabs and Unsplash. The same Node.js process owns configuration, chat records, admin sessions, analytics and the local knowledge base.

```
Browser UI
-> Next.js route handler
  -> validation and configuration
  -> optional search or weather provider
  -> Gemini or Cloudflare AI
  -> local fallback when required
  -> JSON document mutation
  -> debounced PostgreSQL mirror
<- SSE, JSON, image data URL or MPEG audio
```

# 4. Why the AI appears reliable

- \* The chat path has three answer tiers: Gemini stream, Cloudflare complete response, local Ghana knowledge.
- \* Gemini model selection is itself a waterfall. A preferred admin model is tried first, followed by seven configured model names without duplicates.
- \* Web search is optional. Tavily is primary, while Wikipedia and DuckDuckGo are keyless fallbacks.
- \* Weather has three tiers: OpenWeatherMap, Open-Meteo and deterministic seeded output.
- \* The browser receives Server Sent Events and renders Gemini deltas immediately. Cloudflare and local answers are sent in the final done event.
- \* Provider secrets are resolved server-side through lib/env.ts and are never intentionally embedded into the client bundle.

## 5. Assurance verdict

### Verdict

The architecture is understandable and functional as an offline-safe demonstration. Strict type checking, production compilation and PostgreSQL tests passed. Local smoke testing confirmed the public page, configuration, market prices, weather fallback, local chat SSE, session authentication and protected admin reads. This does not mean the application is production hardened. The critical default credential path, public history object access, absent request throttling and vulnerable dependency snapshot must be resolved before high traffic or sensitive deployment.

## 6. Risk register at one glance

| ID   | Severity | Finding                                                                 | Primary evidence                               |
|------|----------|-------------------------------------------------------------------------|------------------------------------------------|
| F-01 | Critical | Known fallback admin credentials work when seed env is absent           | lib/db.ts:166-184, local HTTP login test       |
| F-02 | High     | Public history read, overwrite and deletion by sessionId                | app/api/history/route.ts:8-69                  |
| F-03 | High     | No shared rate limits on cost-bearing or public write routes            | chat, vision, generate, TTS, transcribe routes |
| F-04 | High     | Dependency audit reports three high severity packages                   | next 16.2.10 dependency tree                   |
| F-05 | High     | Public health probe can spend Gemini quota and return raw error text    | app/api/health/route.ts:23-37                  |
| F-06 | High     | Single full-document store risks growth and multi-instance lost updates | lib/db.ts and lib/pg-store.ts                  |
| F-07 | Medium   | Editor sessions can access sensitive content and destructive endpoints  | admin route authorization checks               |
| F-08 | Medium   | No explicit CSRF token or Origin validation                             | all state-changing authenticated routes        |
| F-09 | Medium   | Browser security headers are incomplete                                 | next.config.ts                                 |
| F-10 | Medium   | Search text can inject instructions into the system instruction         | chat route system assembly                     |
| F-11 | Medium   | TTS marks user-derived audio as publicly cacheable                      | app/api/tts/route.ts:55-61                     |
| F-12 | Medium   | Image and audio content validation trusts MIME and base64 shape         | vision and transcribe routes                   |
| F-13 | Medium   | Provider configuration is public and health errors aid fingerprinting   | config and health routes                       |
| F-14 | Medium   | No application encryption, retention job or tamper-evident audit log    | Database schema and admin actions              |
| F-15 | Medium   | CSV export does not quote fields or neutralize spreadsheet formulas     | admin/subscribers route                        |
| F-16 | Low      | X-Powered-By identifies Next.js                                         | local response headers                         |
| F-17 | Low      | Automated coverage is concentrated on PostgreSQL storage                | package.json and scripts                       |
| F-18 | Info     | Seeded product metrics are not backed by evaluation artifacts           | lib/db.ts:79-84                                |

## 7. Scan execution summary

| Control             | Result                  | Meaning                                                                |
|---------------------|-------------------------|------------------------------------------------------------------------|
| npm ci              | PASS with audit warning | 539 packages installed in the scan environment                         |
| TypeScript strict   | PASS                    | No compiler error under tsc --noEmit                                   |
| ESLint              | PASS with 22 warnings   | No lint error, performance and unused import warnings remain           |
| Production build    | PASS with 4 warnings    | 35 pages/routes generated, Edge instrumentation warnings remain        |
| PostgreSQL test     | 14 PASS                 | Create, save, load, debounce, health, hydrate and reset paths executed |
| Dependency audit    | 3 high                  | next, nested postcss and sharp require upgrade                         |
| Secret pattern scan | No live key found       | Two deliberate example database URLs were classified as fixtures       |
| HTTP smoke tests    | 20 behavior checks      | Expected 2xx, 4xx, 5xx, SSE and cookie behavior observed               |

## 8. Evidence limitations

- \* No Google, Cloudflare, Tavily, OpenWeather or ElevenLabs production secret was used. Provider authentication and quota were not independently validated.
- \* No attack was sent to a public production host. Security findings come from static review and a local build.
- \* The checkout history is shallow at the examined commit. The scan proves the state of that commit, not every historical revision.
- \* No agronomic accuracy study, confusion matrix or multilingual human review dataset exists in the checkout.
- \* Generated fallback weather was exercised because outbound Open-Meteo access failed from the isolated test environment.

---

### Authorship and control statement

This volume was prepared, authored and issued solely under the name of Thaddeus Nii Teiko Tagoe. The verdict, risk register and evidence statements in this volume are the controlling summary for the full ten-volume dossier. The repository records identify Thaddeus Tagoe as the founder, sole designer, developer and maintainer of AgriAI.